

温州大学

WENZHOU UNIVERSITY



毕业设计（论文）

文献综述

题目：基于可信执行环境的密态病历信息系统

学院：计算机与人工智能学院 专业：网络工程

班级：22 网工 2 班 学号：22211835217

姓名：唐闫琪 指导教师：卢益彪

关于基于可信执行环境的密态病历信息系统的文献综述

1 研究背景与意义

1.1 研究背景

随着信息技术的飞速发展，电子病历（Electronic Medical Record, EMR）系统已成为现代医疗体系的核心。电子病历极大地提升了医疗服务的效率和质量，但同时也带来了前所未有的数据安全挑战。病历信息作为公民最敏感的隐私数据之一，一旦泄露，不仅会侵犯患者隐私权，还可能被用于欺诈、勒索等非法活动，造成严重的社会危害和经济损失 [1]。

目前，主流的数据保护技术主要集中在“静态保护”（at-rest）和“传输中保护”（in-transit）。“静态保护”通过磁盘加密，防止物理设备丢失导致的数据泄露；“传输中保护”通过 SSL/TLS 等协议，确保数据在网络传输过程中不被窃听。这两种技术都忽略了一个关键环节——“使用中保护”（in-use）。即当病历数据库在执行查询、索引或分析操作时，数据必须被加载到内存中并以明文形式存在，这使得它极易暴露给受损的操作系统、恶意管理员或内存扫描攻击。传统的数据库系统（如 MySQL, Oracle）严重依赖操作系统的安全边界，一旦 OS 被攻破，数据库内的所有隐私将一览无余。因此，如何构建一个不再依赖操作系统信任、能防御底层攻击的“密态数据库系统” [2]，是当前学术界和工业界关注的焦点。

传统的安全模型假设操作系统和管理员是可信的，但在云环境和复杂系统中，这一假设正变得越来越脆弱。因此，如何保护“使用中”的数据，防止来自特权软件和物理攻击的威胁，已成为信息安全领域的迫切需求 [5]。

综上所述，本课题的研究背景源于病历信息隐私保护的需求，意义在于填补现有系统的空白，提供一体化解决方案。

1.2 研究意义

本研究旨在探索可信执行环境（TEE）在数据库安全领域的应用范式。通过将数据库引擎的核心逻辑（索引、查询、存储）封装在 TEE 内部，本课题有助于验证“最小特权原则”在复杂数据管理系统中的可行性，为构建“零信任”数据处理架构提供理论依据。从应用层面看，构建基于 Intel SGX 的密态病历系统具有重要的现实价值：隐私合规：能够从技术底层满足《个人信息保护法》等法律法规对敏感个人信息保护的严苛要求。抵御内部威胁：即使数据库管理员（DBA）或云服务提供商持有服务器权限，也无

法窥探患者隐私，从而解决医疗数据“共享难、信任难”的痛点。促进数据流通：为医疗数据的跨机构安全共享和远程医疗应用提供安全可信的技术底座 [9]。

2 国内外研究现状和分析

近年来，围绕可信执行环境（Trusted Execution Environment, TEE）及其在医疗数据保护与机密计算领域的应用，国内外学术界与产业界均开展了大量研究。同时学术界围绕 TEE 技术在数据管理与数据库安全领域的应用进行了广泛研究。研究重点已从早期的简单代码隔离，转向构建功能完备的密态数据库系统（Encrypted Database Systems），即利用 Intel SGX 实现数据的密态存储、安全索引和隐私保护查询，这正是本文研究的重点所在。

2.1 国外研究现状

可信执行环境（Trusted Execution Environment, TEE）作为保护“使用中数据安全”的核心技术，在国际学术界与产业界均成为热点研究方向。TEE 技术的研究主要聚焦于硬件隔离机制、可信根设计、侧信道防护、工程化支持及性能优化等多个层面。同时国外在基于 TEE 的数据管理系统方面起步较早，主要技术路线包括“现有数据库的迁移保护”和“专用密态数据库的构建”。在专用安全数据管理系统方面，Zhou 等人设计了一种基于 TEE 的工业物联网数据管理系统。该系统针对时间序列数据设计了专门的 Enclave 内索引机制，实现了数据的端到端保护。然而，该方案主要针对流式数据设计，缺乏对医疗病历这类复杂结构化数据（如包含多字段的关系统数据）的高效增删改查支持。在通用数据库保护方面，Coppolino[13] 等人设计了 SCONE 系统。SCONE 通过容器化技术，允许用户将现有的数据库软件（如 Redis, MySQL）直接运行在 SGX Enclave 内部。虽然这种方法能快速实现数据库的密态化，但由于整个数据库引擎都被放入 Enclave，导致可信计算基（TCB）极其庞大，增加了因代码漏洞导致的安全风险。在大数据分析查询方面，Wang Z [12] 等人提出了 VC3 系统。该系统利用 SGX 保护分布式 MapReduce 计算中的数据查询与聚合操作，解决了云端数据分析的信任问题。但 VC3 侧重于离线批处理分析，难以满足医疗信息系统对实时事务处理（OLTP）和低延迟单条病历查询的需求。

2.2 国内研究现状

国内研究在贴合法规合规方面表现出特色。罗楚瑶 [3] 设计了基于 SGX 的多方数据安全计算模块，重点考虑了《个人信息保护法》等法规要求，但在大规模医疗数据场

景下的性能表现有待优化。张琰脐 [6] 探索了机密计算在隐私数据共享中的应用，提出了符合国内数据安全标准的技术路径，但方案在跨机构数据协同方面仍面临挑战。

为了解决“使用中”数据的保护难题，可信执行环境（Trusted Execution Environment, TEE）技术应运而生。TEE 是一种基于硬件的安全解决方案，它为主处理器内部创建一个隔离的安全区域，通常被称为“飞地”（Enclave）。

Intel Software Guard Extensions (Intel SGX) 是目前业界最具代表性的 TEE 实现之一。SGX 允许应用程序在内存中划分出一块被称为 Enclave 的区域。这块区域受到 CPU 硬件的强制保护，其内部的代码和数据对外部环境（包括操作系统、驱动程序、BIOS 甚至物理探针）都是加密和隔离的。即便是拥有最高权限的管理员或操作系统内核，也无法读取或篡改 Enclave 内部的明文数据 [4]。

远程证明（Remote Attestation）是 SGX 的关键特性之一，它允许远程用户验证运行在服务器上的 Enclave 是否真实可信，确保没有恶意软件伪装成合法的 Enclave。密封（Sealing）机制则允许 Enclave 将数据加密存储到磁盘，确保只有特定的 Enclave 才能解密这些数据 [8]。

3 研究的发展趋势和展望

随着数据安全威胁形态的不断演进，传统依赖“静态加密”和“传输加密”的安全机制已难以应对复杂应用场景下的数据泄露风险。尤其是在数据被加载并参与计算的“使用中”阶段，长期缺乏有效的保护手段，成为当前信息系统安全体系中的关键薄弱环节。在此背景下，基于 Intel SGX（Software Guard Extensions）等可信执行环境（Trusted Execution Environment, TEE）的安全计算技术逐渐成为学术界与产业界的研究热点。

3.1 现有研究不足

虽然国内外在“密态数据库”领域已取得丰硕成果，但直接应用于“病历信息系统”仍存在以下局限：

（1）通用性与专用性的矛盾：像 SCONE 这类通用方案 TCB 过大，安全性存疑；而像许书宁等人的专用方案仅专注于“搜索”这一单一功能，缺乏完整的数据库管理能力（如事务、多表关联）。

（2）医疗场景适配不足：现有密态数据库研究大多关注底层索引或查询算法，缺乏针对医疗场景中“医患多角色权限隔离”与“病历结构化存储”相结合的系统级设计。

（3）性能瓶颈依然存在：数据库操作涉及频繁的 I/O 和内存访问，在 SGX 环境下，频繁的 Enclave 进出（Transition）和内存加密开销严重制约了系统的响应速度。

因此，本课题拟设计一个轻量级的密态病历数据库引擎，结合细粒度访问控制和 Switchless 优化技术，在保障数据全生命周期安全的同时，提供高效的病历管理服务。

3.2 未来趋势

(1) 实现“全生命周期”的数据密态保护未来基于 Intel SGX 等 TEE 技术的数据安全体系，将实现对数据存储、传输与处理全过程的统一保护，从根本上填补传统加密技术在“使用中数据保护”方面的安全空白。通过将敏感数据的解密、计算和访问控制全部限定在 Enclave 内部执行，系统能够在不暴露明文数据的前提下完成业务处理，真正实现“数据始终处于受保护状态”的全生命周期安全模型。这一技术路线被认为是下一代高安全信息系统的重要发展方向。

(2) 隐私计算技术的融合与协同单一的隐私保护技术往往难以应对复杂场景。未来的趋势是将 TEE 与联邦学习 (Federated Learning)、多方安全计算 (MPC) 等技术深度融合。例如，在医疗联合建模场景中，利用 TEE 作为“可信聚合节点”来保护联邦学习的中间梯度，既解决了 MPC 计算效率低的问题，又解决了传统联邦学习存在的梯度隐私泄露风险，实现性能与安全的双重提升。

(3) 硬件架构的异构化与标准化演进机密计算硬件正在从单一的 CPU 扩展(如 SGX)向更广泛的架构演进。Intel TDX (Trust Domain Extensions) 和 AMD SEV-SNP 等新一代技术正在将保护粒度从“应用层”扩展到“虚拟机层”，通过硬件加密整个虚拟机内存，大幅降低了遗留系统的迁移成本。同时，随着 Confidential Computing Consortium (CCC) 等组织的推动，跨平台的机密计算标准将逐渐成熟，使得密态病历系统在不同硬件平台间的迁移与部署更加平滑。

4 研究的基本内容与拟解决的主要问题

4.1 研究的基本内容

本系统的核心目标是构建一个基于 Intel SGX 的安全病历管理系统，实现从用户认证到数据操作的全程密态处理，确保即使系统被攻破，病历明文数据也不会泄露。系统设计了三类权限明确的角色。患者拥有对自己基本信息的读写权和对自已病历的只读权；医生拥有对患者基本信息的只读权和对病历的读写权；管理员仅负责持有 SGX 硬件环境和系统的初始化部署，无法接触任何业务数据。基于非对称加密的身份认证：研究并在 Enclave 内部实现基于 RSA 或 ECC 算法的公钥认证体系。管理员对用户身份进行离线核验后，用户在本地生成密钥对，将公钥通过安全通道注册至 Enclave 内部的白名单中。登录时，Enclave 通过验证用户签名的挑战值 (Challenge-Response) 来完成身份

认证，全程杜绝口令明文传输。患者基本信息的 **Enclave** 内密态管理安全数据结构设计：在 **Enclave** 内存空间中设计专门的数据结构（如 **C++ STL Map** 或自定义安全链表）来暂存解密后的患者基本信息（姓名、身份证号、联系方式等）。细粒度访问控制（**RBAC**）：在 **Enclave** 内部编写可信逻辑，强制执行访问控制策略。例如，当收到“修改信息”请求时，**Enclave** 会首先校验发起者的数字签名是否属于“患者本人”，只有验证通过才允许执行写操作，否则直接拒绝，从而防止越权访问。患者病历信息的全生命周期密态处理密态 **CRUD** 逻辑：实现病历信息（诊断记录、处方、检查报告）的增删改查逻辑。所有操作均通过加密的 **ECall** 接口传入，数据仅在 **CPU** 内部的 **Enclave** 隔离区解密为明文进行处理，处理完成后立即在 **Enclave** 内重新加密输出，确保明文数据“不落地”。

4.2 拟解决的问题

本课题在设计与实现过程中，主要致力于攻克以下关键问题：

(1) 可信信道的建立难点：在开放网络环境下，客户端如何确认连接的是真实的“密态数据库”而非恶意模拟器？

(2) 密态数据处理的逻辑封闭性：如何设计代码逻辑，使得所有涉及病历明文的操作（如姓名检索、病情修改）严格限制在 **Enclave** 内部，杜绝中间数据的溢出风险

(3) **TEE** 开发环境的构建与适配难点：解决如何在硬件受限或无硬件支持的环境下进行系统开发。拟研究并利用 **SGX SDK** 提供的 **Simulation Mode**（模拟模式），该模式允许在普通 **CPU** 上模拟 **Enclave** 的指令执行和内存隔离。通过攻克模拟环境与硬件环境的差异性问题的，确保系统在普通开发机上也能完成编码与逻辑验证，降低开发门槛。

5 总结与展望

本课题拟在前人研究的基础上，避开通用大系统的臃肿架构，采用轻量级定制开发路线；摒弃低效的纯同态加密，利用 **SGX** 硬件隔离实现高效的密态 **CRUD**；引入 **Switchless** 技术解决高频交互的性能痛点。最终构建一个安全、高效且符合医疗业务特性的密态病历信息系统。尽管目前 **TEE** 技术在性能和开发复杂度上仍面临挑战，但随着硬件性能的提升和 **Switchless** 等优化技术的成熟，基于 **TEE** 的密态数据库必将在未来的智慧医疗、隐私计算领域占据核心地位。

参考文献

- [1] 李旖旎. 基于 Intel SGX 的工业互联网平台数据隐私保护机制研究 [J]. 电脑编程技巧与维护, 2024.
- [2] 许书宁. 基于可信执行环境的可搜索加密数据库研究 [D]. 华中科技大学, 2024.
- [3] 罗楚瑶. 基于 SGX 的多方数据安全计算密码模块设计与实现 [D]. 西安电子科技大学, 2024. DOI:10.27389
- [4] 梁子原. 多方场景下的软硬件协同的隐私数据安全技术研究 [D]. 浙江大学, 2023. DOI:10.27461
- [5] 高天. 基于可信执行环境的安全数据存储机制研究 [D]. 南京理工大学, 2023. DOI:10.27241
- [6] 张琰脐. 基于机密计算的隐私数据安全共享模型的研究与实现 [D]. 华南理工大学, 2022.
- [7] 杨光远, 杨大利, 张羽, 等. 基于可信硬件的隐私数据可搜索加密加速方法研究 [J]. 信息安全研究, 2021, 7(04): 319-327.
- [8] 苟旭春. 基于 SGX 的远程程序敏感变量隐藏技术研究 [D]. 西安电子科技大学, 2022.
- [9] 韦衡纳, 郑晓琦. 基于大数据的医疗信息系统平台构建与应用 [J]. 互联网周刊, 2025, (01): 48-50.
- [10] Ahmed F. Blockchain-Driven Privacy and Security Protection in Decentralized Data Sharing Systems[D]. 中国科学技术大学, 2024. DOI:10.27517
- [11] 王烁程. 面向新一代 Intel 可信执行环境的性能优化方案 [D]. 南京大学, 2021. DOI:10.27235
- [12] Will N C, Maziero C A. Intel Software Guard Extensions Applications: A Survey[J]. ACM Computing Surveys, 2023, 55(14s): 1-38.
- [13] Wang Z, Zhou Y. Analysis and Evaluation of Intel Software Guard Extension-Based Trusted Execution Environment Usage in Edge Intelligence and Internet of Things Scenarios[J]. Future Internet, 2025, 17(1): 32.
- [14] Coppolino L, D'Antonio S, Formicola V, et al. VISE: Combining Intel SGX and Homomorphic Encryption for Cloud Industrial Control Systems[J]. IEEE Transactions on Computers, 2020, 70(5): 711-724.
- [15] Zhou C, Barati M. A TEE-Guarded Data Management System for Time-Scale Data in Industrial Internet of Things[J]. IEEE Internet of Things Journal, 2025.

- [16] Zheng W, Wu Y, Wu X, et al. A Survey of Intel SGX and Its Applications[J]. *Frontiers of Computer Science*, 2021, 15(3): 153808.